PANDUAN KHUSUS MITIGASI ANCAMAN SIBER

PANDUAN STRATEGI PENCEGAHAN RANSOMWARE UNTUK BISNIS

Sistem Proteksi Berlapis, Pertahanan Cadangan Data & Tanggap Darurat Kebocoran Data v1.0

Peringatan Utama: Ransomware modern tidak hanya mengenkripsi berkas (*single extortion*), tetapi juga mencuri data sensitif sebelum dienkripsi (*double extortion*) untuk mengancam pembocoran data ke publik. Bayar tebusan **SANGAT TIDAK DIREKOMENDASIKAN** karena tidak menjamin pemulihan data dan mendanai kejahatan siber.

1. Vektor Utama Infeksi Ransomware pada Organisasi

Memahami bagaimana ransomware menembus pertahanan bisnis untuk menutup aksesnya secara efektif:

Phishing & Rekayasa Sosial

Email berbahaya berisikan lampiran bertipe dokumen makro, file ZIP tersandi, atau link jebakan yang mengunduh program peretas (*payload*).

Exposed RDP & Remote Access

Port Remote Desktop Protocol (3389) atau VPN tanpa MFA yang langsung terbuka ke internet publik, dieksploitasi dengan metode *brute-force*.

Celah Sistem Tak Ter-patch

Kerentanan pada OS server, VPN gateway, atau CMS yang tidak diperbarui secara berkala (*Unpatched Vulnerabilities*).

Supply Chain & Pihak Ke-3

Akses jaringan dari vendor atau aplikasi pihak ketiga yang memiliki standar keamanan lebih rendah terkompromi terlebih dahulu.

2. Strategi Cadangan Data Anti-Ransomware (Strategi 3-2-1-1)

Penyimpanan cadangan (*backup*) biasa yang terhubung langsung ke jaringan sering kali ikut terenkripsi saat ransomware menyerang. Terapkan standar **3-2-1-1**:

Elemen	Ketentuan Teknis	Proteksi Ransomware
3 Salinan Data	1 data produksi utama + 2 data cadangan tambahan.	Meminimalisir risiko kegagalan satu media.
2 Media Berbeda	Gunakan media fisik berbeda (misal: NAS dan Object Storage Cloud).	Mencegah kerusakan akibat hardware tunggal.
1 Lokasi Offsite	Simpan satu salinan di luar fasilitas kantor utama.	Perlindungan dari bencana fisik lokal.
1 Salinan Immutable / Offline	Simpan data dalam format **Write-Once-Read-Many (WORM)** atau terisolasi penuh dari jaringan (*Air-gapped*).	Data tidak dapat diubah, dihapus, atau dienkripsi oleh ransomware walaupun akses admin terkompromi.

3. Langkah Kontrol Teknis & Hardening Infrastruktur

Implementasikan pengamanan teknis berikut untuk membatasi ruang gerak peretas (*lateral movement*):

- **Proteksi Endpoint Berbasis AI (EDR/XDR):** Gantikan antivirus konvensional dengan *Endpoint Detection and Response* (EDR) yang dapat menghentikan proses enkripsi abnormal secara otomatis.
- **Pembatasan Hak Akses Administrator:** Terapkan *Privileged Access Management (PAM)* dan batasi akses lokal admin. Jangan biarkan karyawan harian menggunakan akun berhak akses administrator.
- **Blokir Script & Macro Otomatis:** Nonaktifkan eksekusi Macro pada Microsoft Office dari berkas luar dan blokir eksekusi skrip (*PowerShell*, *VBScript*, *Batch*) untuk pengguna umum.
- **Matikan Protokol Usang:** Nonaktifkan protokol SMBv1, NetBIOS, dan RDP publik di seluruh jaringan lokal kantor.
- **Multi-Factor Authentication (MFA) Wajib:** Terapkan MFA berbasis token/authenticator app untuk seluruh akses VPN, Cloud Console, dan Portal Email Perusahaan.

4. Protokol Tanggap Darurat Kritis jika Terindikasi Serangan

Jika ditemukan file ber-ekstensi aneh atau catatan tebusan (*ransom note*) di salah satu komputer:

1. **ISOLASI FISIK SEGERA (Segera Putuskan Kabel LAN & Wi-Fi):** Cabut kabel jaringan atau matikan Wi-Fi pada perangkat terdampak detik itu juga. Jangan matikan komputer terlebih dahulu agar bukti forensik memory RAM tidak hilang.
2. **ISOLASI JARINGAN SERVER:** Putuskan koneksi antar-VLAN dan isolasi server *backup* utama agar ransomware tidak menyebar ke media penyimpanan cadangan.
3. **ISOLASI AKUN DOMAIN:** Lakukan *Disable* atau *Reset Password* pada akun admin dan domain yang terkompromi secara menyeluruh.
4. **LAPORKAN & ANALISIS:** Hubungi Tim Keamanan IT/CSIRT internal dan lembaga terkait. Identifikasi jenis strain ransomware melalui analisis ekstensi file dan hash.
5. **RECOVERY DARI IMMUTABLE BACKUP:** Bersihkan seluruh sistem yang terinfeksi (*wipe & re-image*) sebelum melakukan proses pemulihan data dari salinan cadangan yang aman.